Report

Subdomain Takeover and Broken Link Hijacking

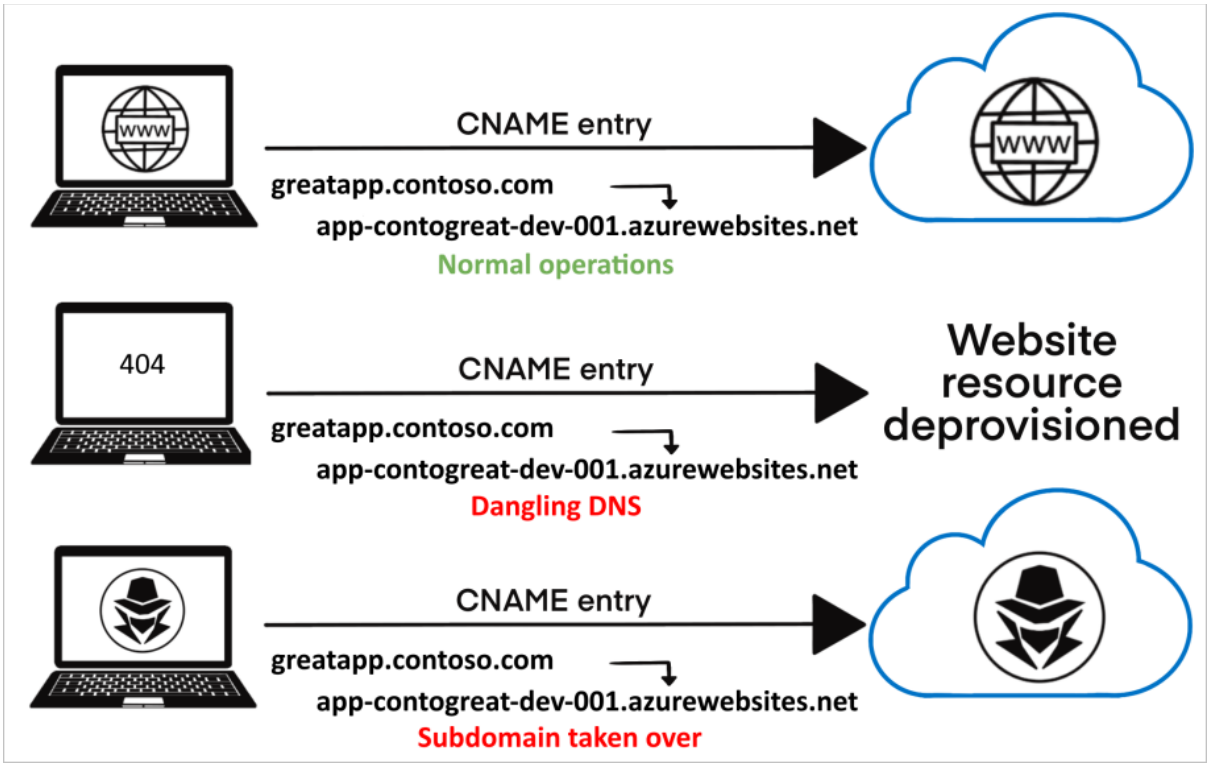
Suyash A Gunjal

Subdomain Takeover

What is subdomain takeover?

A subdomain takeover occurs when an attacker gains control over a subdomain of a target domain. Typically, this happens when the subdomain has a canonical name (CNAME) in the Domain Name System (DNS), but no host is providing content for it. This can happen because either a virtual host hasn't been published yet or a virtual host has been removed.

An attacker can take over that subdomain by providing their own virtual host and then hosting their own content for it.



Test Objectives

- Enumerate all possible domains (previous and current).
- Identify any forgotten or misconfigured domains.

How to Test

The first step is to enumerate the victim DNS servers and resource records. There are multiple ways to accomplish this task; for example, DNS enumeration using a list of common subdomains dictionary, DNS brute force or using web search engines and other OSINT data sources.

Using the dig command the tester looks for the following DNS server response messages that warrant further investigation:

- NXDOMAIN
- SERVFAIL
- REFUSED
- no servers could be reached.

Remediation

To mitigate the risk of subdomain takeover, the vulnerable DNS resource record(s) should be removed from the DNS zone. Continuous monitoring and periodic checks are recommended as best practice.

Broken Link Hijacking

What is Broken Link Hijacking?

Broken Link Hijacking (BLH) is a web-based attack where the attackers take over expired, stale, and invalid external links on credible websites/ web applications for malicious/ fraudulent purposes.

These external links are used for a multitude of purposes ranging from SEO to load resources from external URLs/ points. These links may expire or become invalid, for instance, owing to domain expiry. And the attacker takes control of

the resource at the other end of such a link somehow and uses it to fulfill his/her motives.

What Makes BLH Attacks Possible?

Link Hijacking attacks occur because the website/ web application continues to contain links to expired/ stale resources/pages (loaded using external URLs).

Given the relentless transformation of the Web, all externally loaded resources will not remain unaltered and accessible forever.

There could be domain expiry, deletion of page/ resource/ account, website restructuring, business rebranding / acquisition, etc. that could cause outbound links to rot/ expire.

Examples of broken link hijacking

With thousands of domains expiring every day, broken links are common. Not all these results in broken link hijacking but all have the potential to do so. Here is the noteworthy example.

- In 1999, Microsoft forgot to renew the passport.com domain used by its Hotmail email service. The renewal was picked up by a random Internet user, who then contacted Network Solutions. Microsoft thanked the user with a $500 check, which was then auctioned off for charity. Microsoft made another mistake in 2003, this time allowing a private individual to purchase the domain *hotmail.co.uk*, fortunately also without malicious intent.

How to Detect Broken Link Hijacking (BLH) ?

- Use vulnerability scanners or broken-link checkers to find dead or incorrect external links, but note they can't detect all cases because many expired domains show valid-looking placeholder pages.
- The only reliable method is regular manual security testing, since automated tools may miss hijackable links that don't return obvious errors.

How to prevent broken link hijacking?

To minimize the risk of broken link hijacking, avoid using third-party services for link shortening and file hosting. If you must use a third-party service because you cannot develop or host your own, pick well-known ones that have been operational for a long time and are unlikely to go out of business. And above all, make certain that none of your own domains expire.

References:

https://developer.mozilla.org/en-US/docs/Web/Security/Attacks/Subdomain_takeover

https://learn.microsoft.com/en-us/azure/security/fundamentals/subdomain-takeover

https://www.invicti.com/learn/broken-link-hijacking-blh